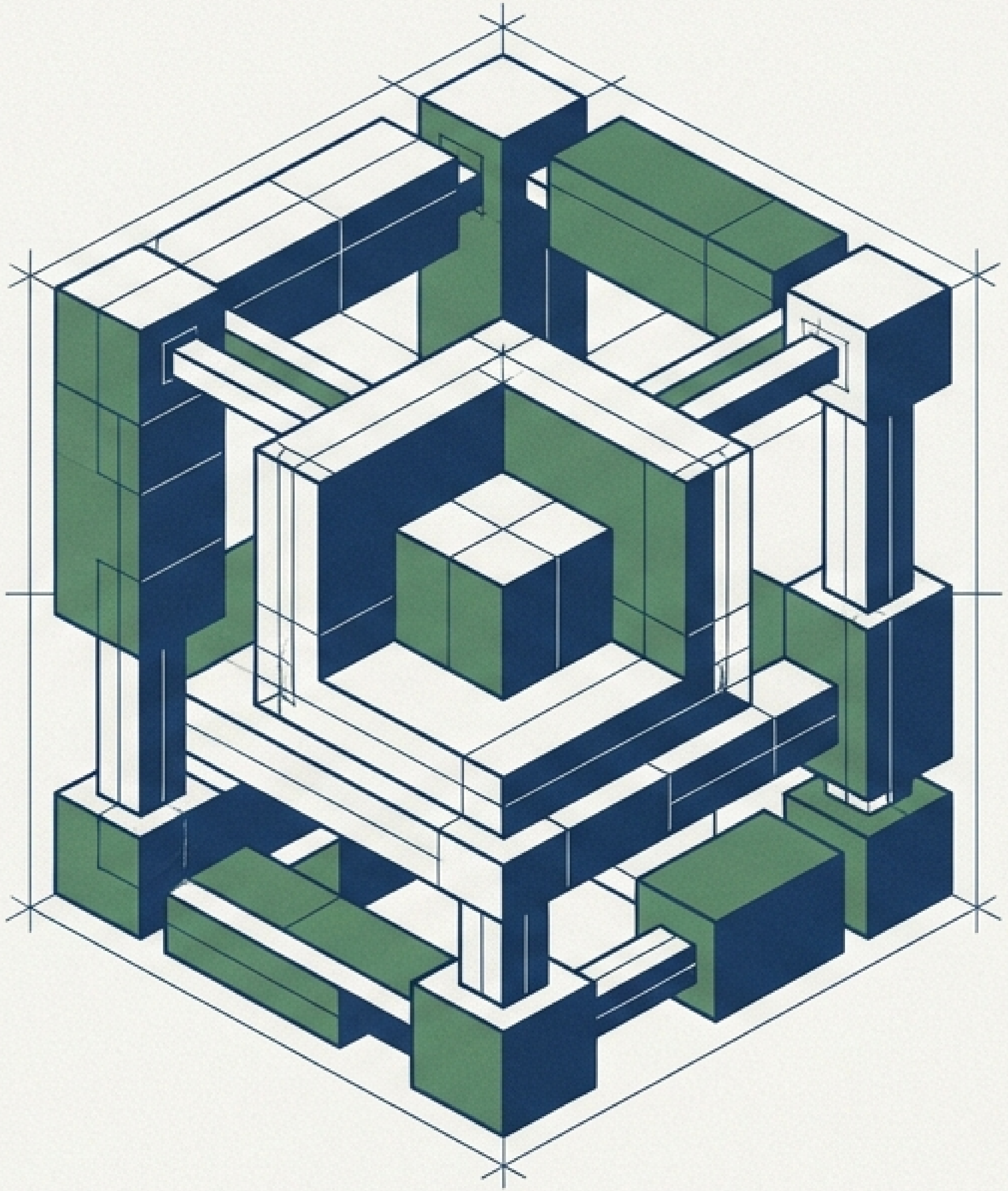
Evaluating GenAI Startups in Cybersecurity

An Analysis Framework

Authored by Dinis Cruz

March 2026

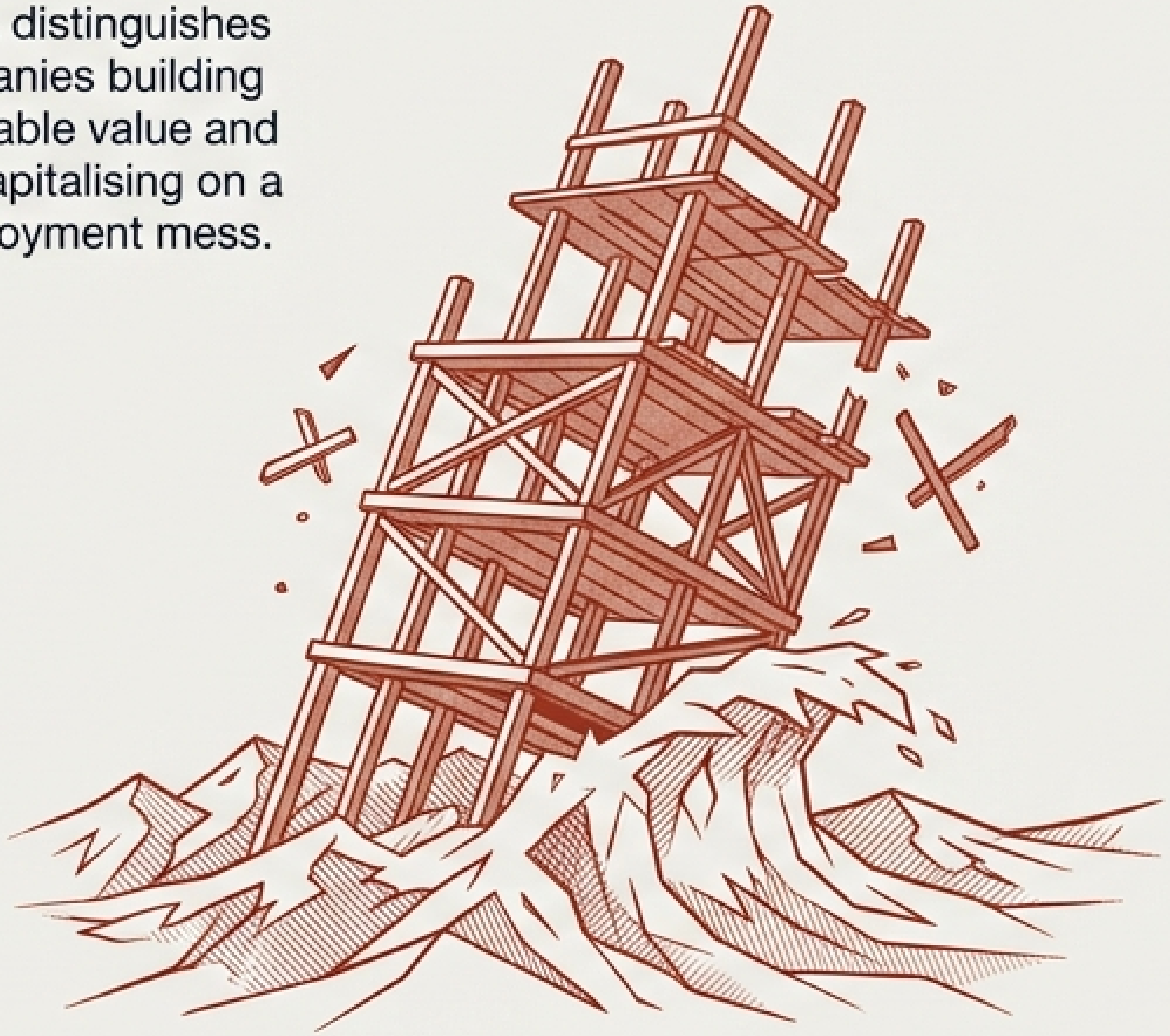


Designed for investors, founders, enterprise buyers, and cybersecurity practitioners.

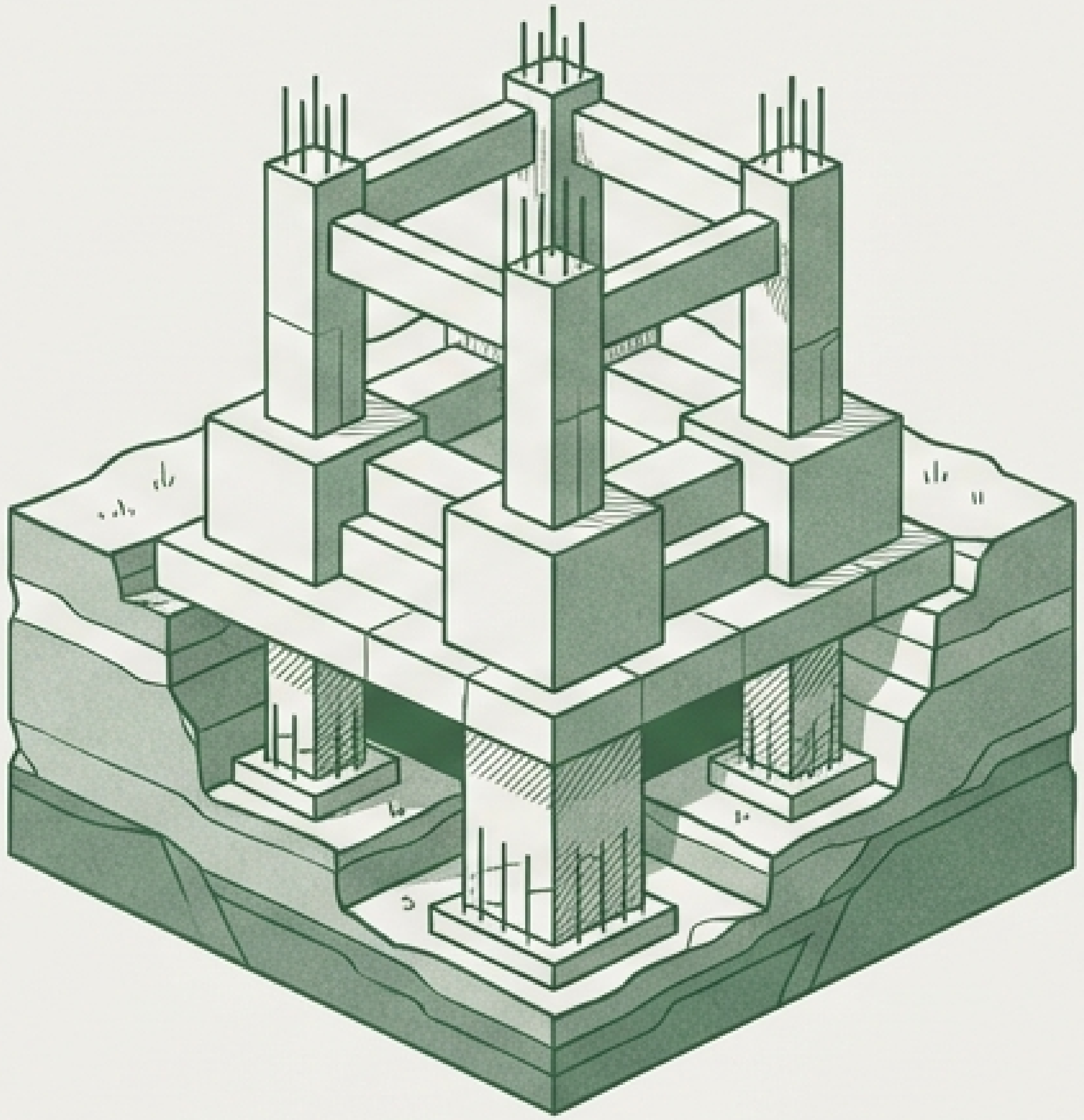
Separating Durable Value from Temporary Waves

Many GenAI cybersecurity startups are solving the wrong problem, or solving the right problem in a way that will not survive the next model improvement.

This framework distinguishes between companies building structurally durable value and those merely capitalising on a temporary deployment mess.



TEMPORARY WAVES:
PRECARIOUS CAPITALISATION



STRUCTURALLY DURABLE VALUE:
DEEP ARCHITECTURAL FOUNDATION

Cybersecurity History Consistently Repeats Itself

Technical-only solutions get commoditised; business-context solutions endure.

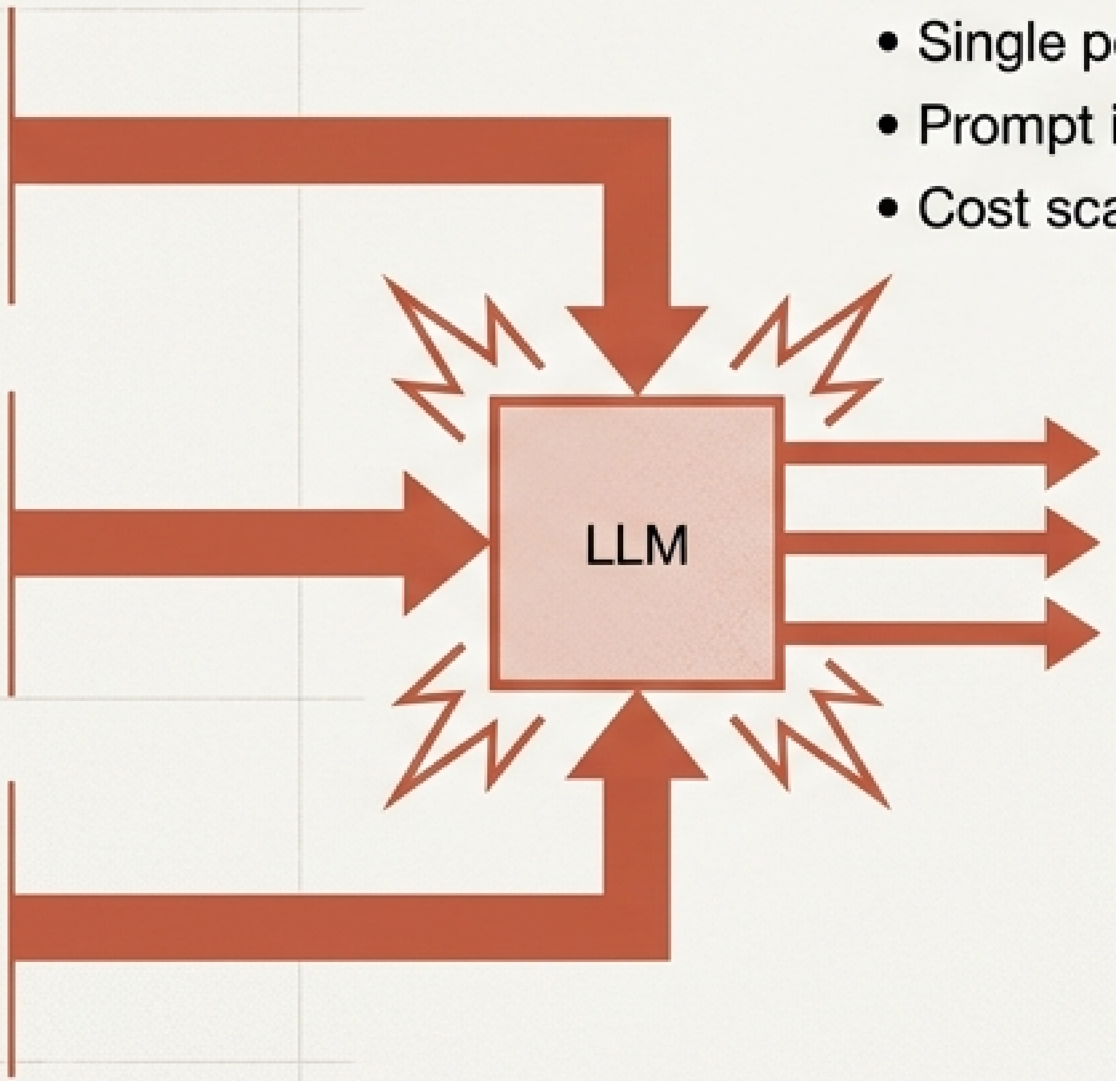
Early Firewalls	SIEM	Cloud Security	Endpoint Security	GenAI Security (Now)
We inspect all traffic	We collect all logs	Shadow IT discovery	Signature-based AV	Prompt injection detection
Evolved to application context	Evolved to SOAR/XDR modelling business rules	Evolved to DevOps integration	Evolved to EDR behavioural analysis	Survival requires modelling workflows

Technical-only solutions get commoditised; business-context solutions endure.

Fragile Inline Models Versus **Durable Deterministic** Execution

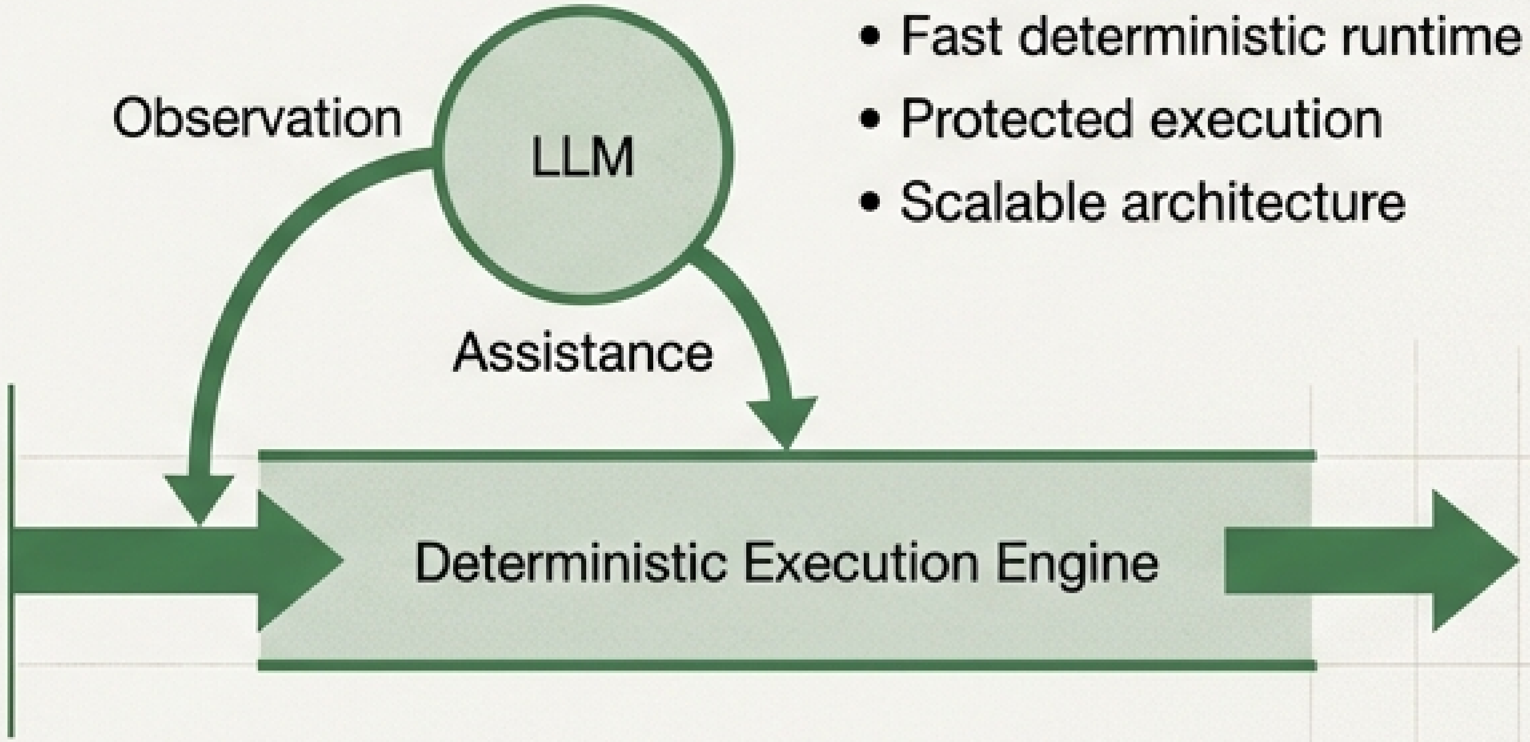
The Key Question: Is the AI an inline execution engine adding complexity, or an agentic assistant building deterministic business rules?

Fragile Pattern: LLMs Inline



- Single point of failure
- Prompt injection risk
- Cost scales linearly

Durable Pattern: Agentic Development



- Fast deterministic runtime
- Protected execution
- Scalable architecture

Criterion 1 Diagnoses Structural Needs Over Temporary Messes

The question to ask: If every enterprise had perfect visibility and control over their AI deployments tomorrow, would this company still have a product?

Temporary Mess

Acute demand for shadow AI governance. A symptom of immature adoption.

Structural Problem

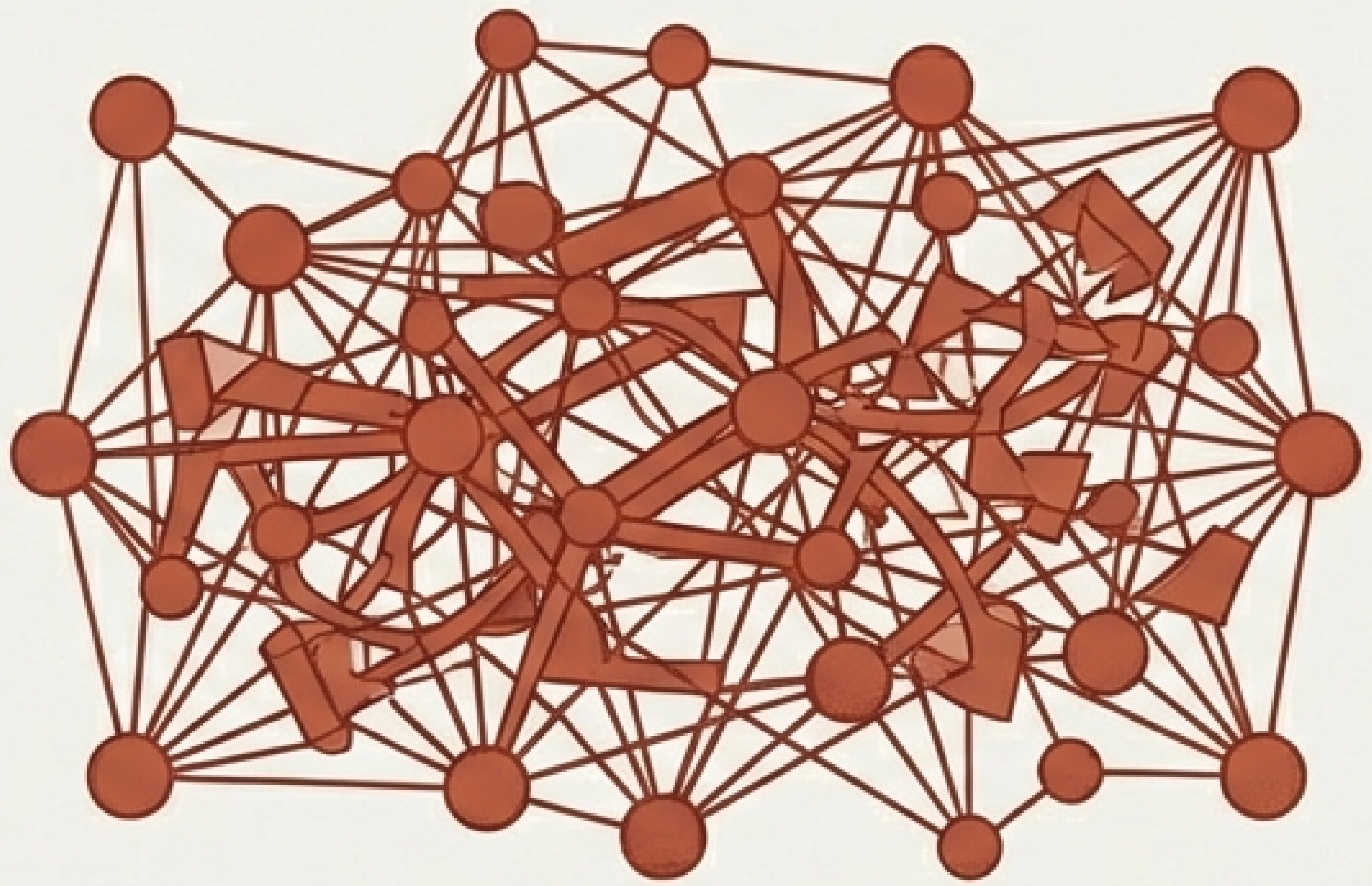
Context, permissions, data provenance. These These get harder as GenAI scales.

Criterion 2 Demands Immediate Unit Value Without Mass Adoption

The Paradox: Selling a solution for out-of-control AI that requires the AI to be completely under control and routed through one point to work.

The question to ask: Can this product deliver value on a single use case for a single team on day one, or does it require a massive enterprise-wide rollout to show any benefit?

Unit Value



Mass Adoption

Criterion 3 Highlights the Operational Risks of Inline Deployments

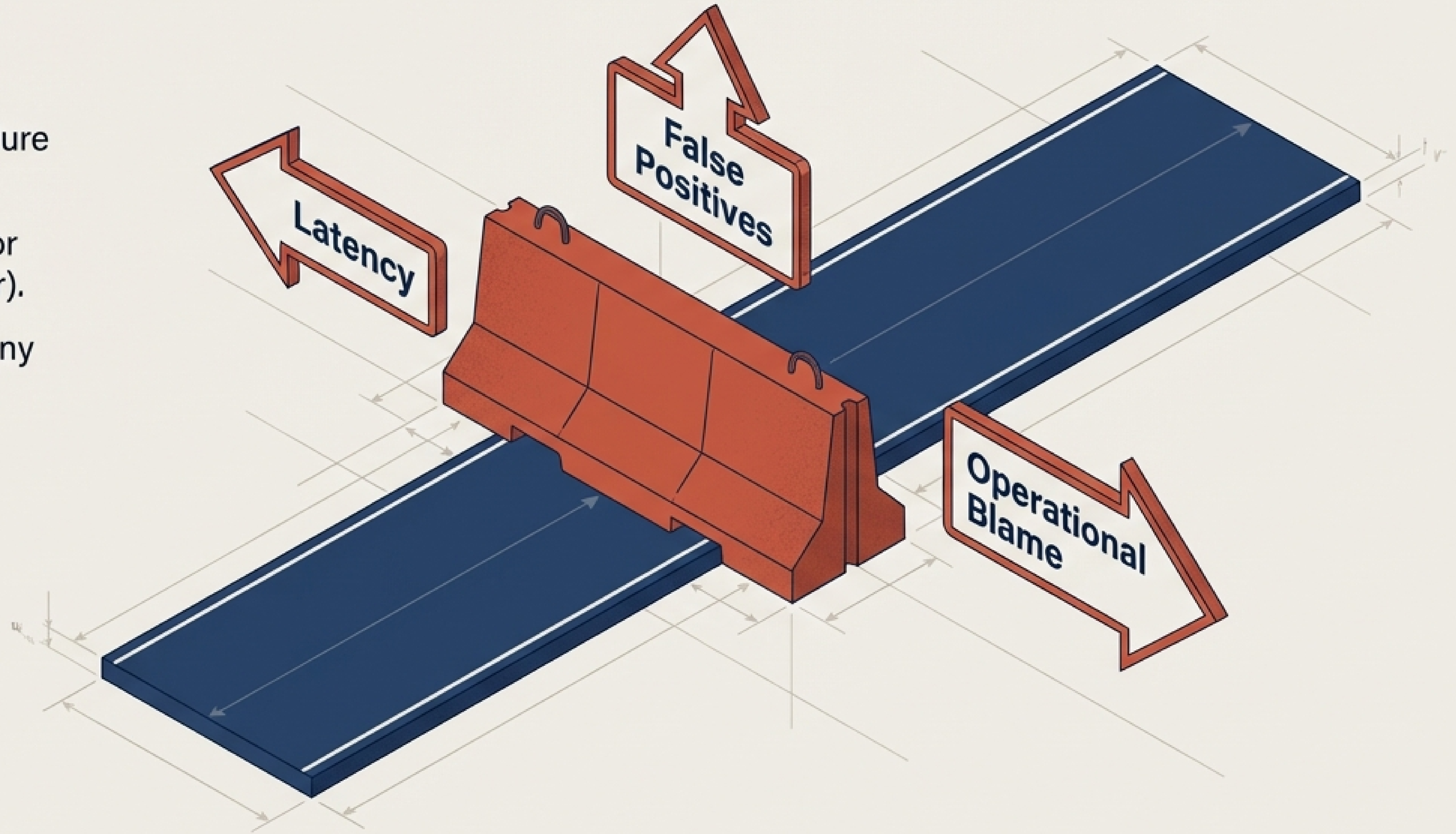
The question to ask: How do they handle false positives, latency, and inevitable operational blame?

Core Risks of Going Inline:

Becoming a single point of failure (their outage is your outage).

Context edge cases (benign for one team, violation for another).

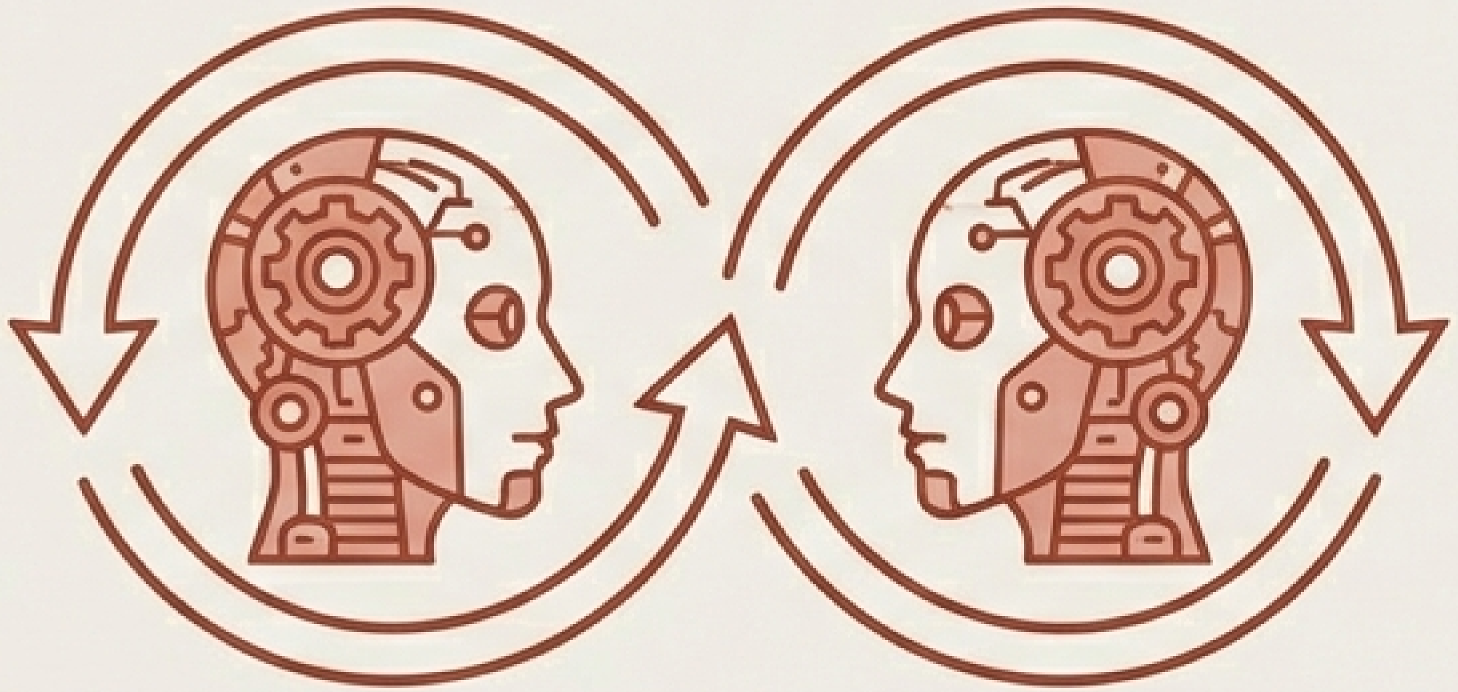
Becoming the scapegoat for any system friction.



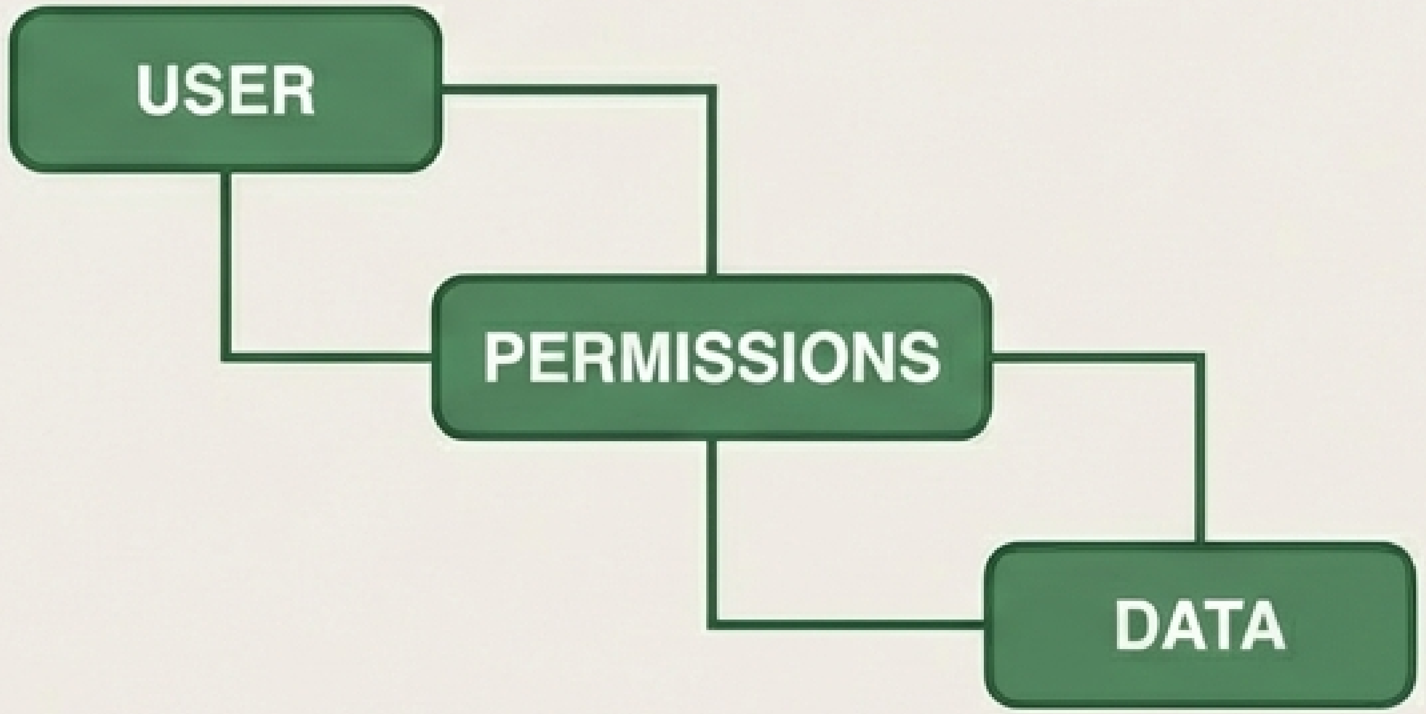
Criterion 4 Prioritises Modelling Business Context Over Technical Pattern Matching

Key Insight: Prompt injection detection is a technical problem models will eventually solve natively. State, ownership, and workflows are durable business problems.

The question to ask: How does the system handle a prompt that is dangerous in Department A but legitimate in Department B?



Red Flag: LLMs judging LLMs

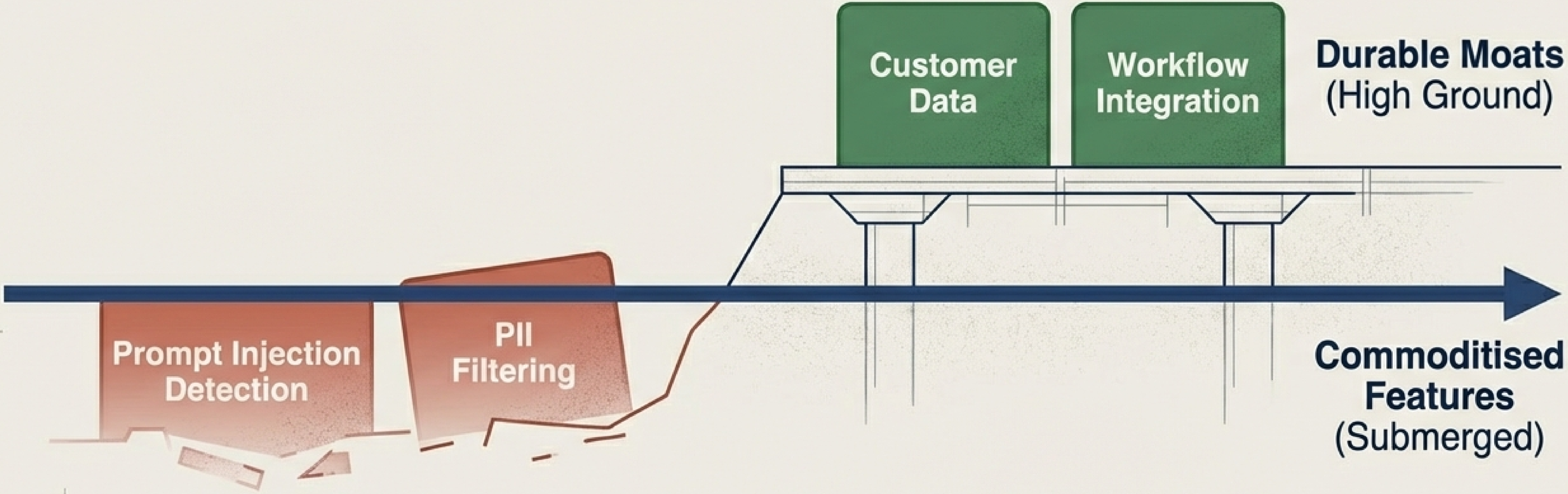


Green Flag: Deterministic business rules

Criterion 5 Tests Survivability When the Next Foundation Model Ships

The Threat: Building products on top of the current errors of LLMs is a losing bet. Attrition of model providers is not a business strategy.

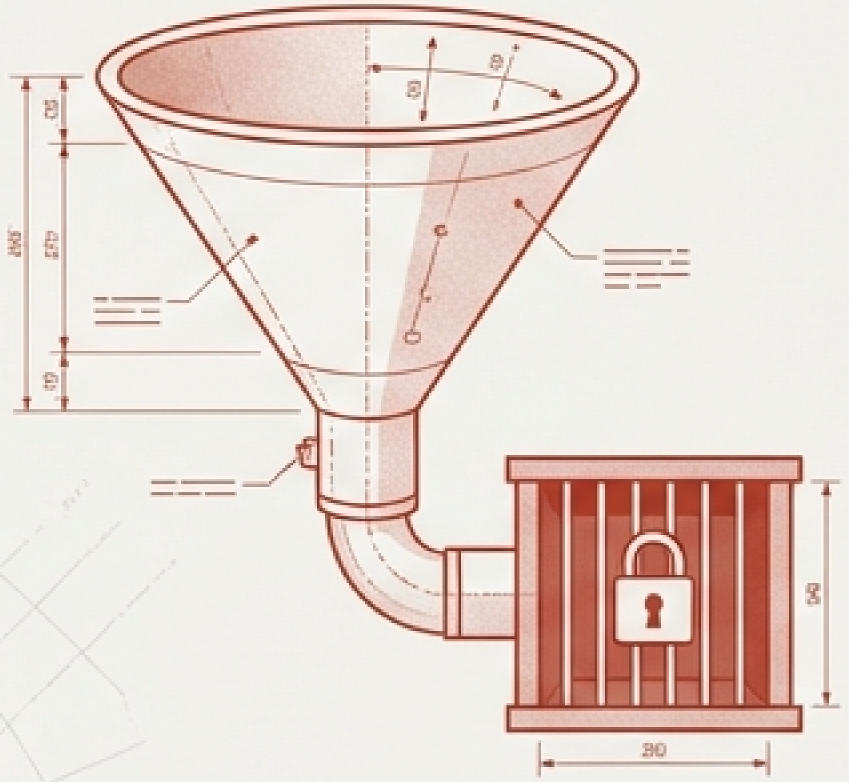
The question to ask: When the next generation of models arrives, does this company get better, or gain a competitor?



Criterion 6 Differentiates Genuine Open Source from Marketing Lock-In

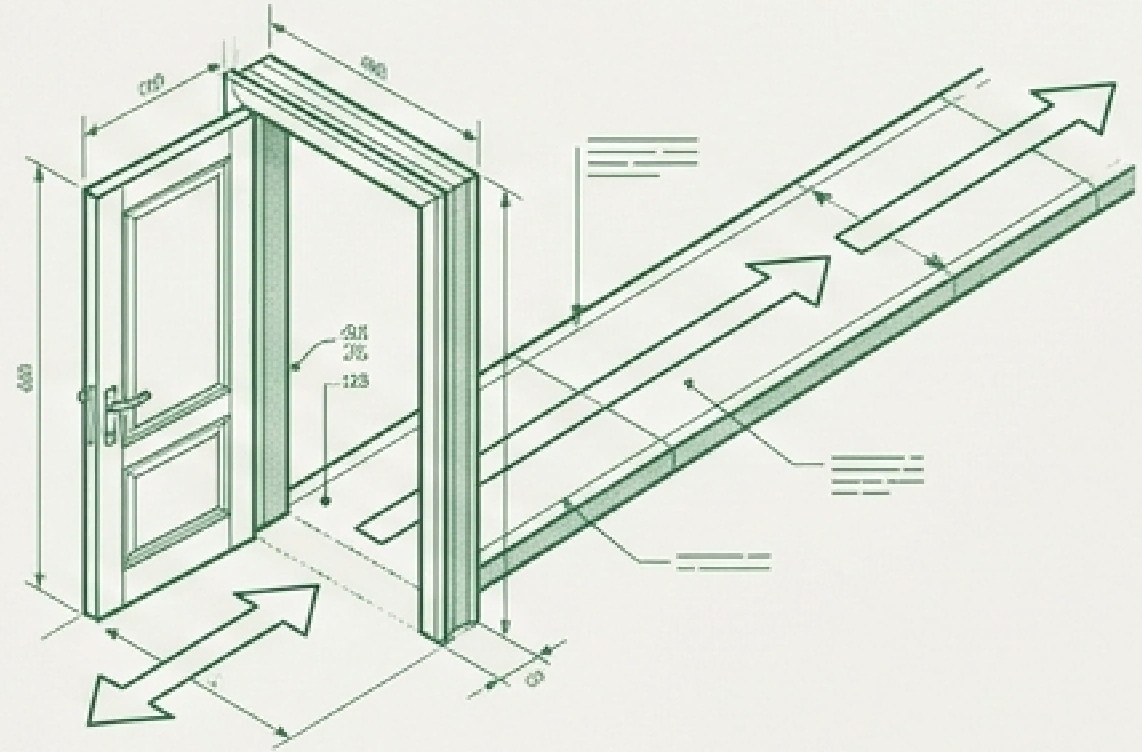
The Test: Can a motivated team take the open source project and solve a real problem end-to-end without purchasing anything?

Lock-in Strategy



Marketing funnel.
Internal debates favour the paid product.

Genuine Open Core



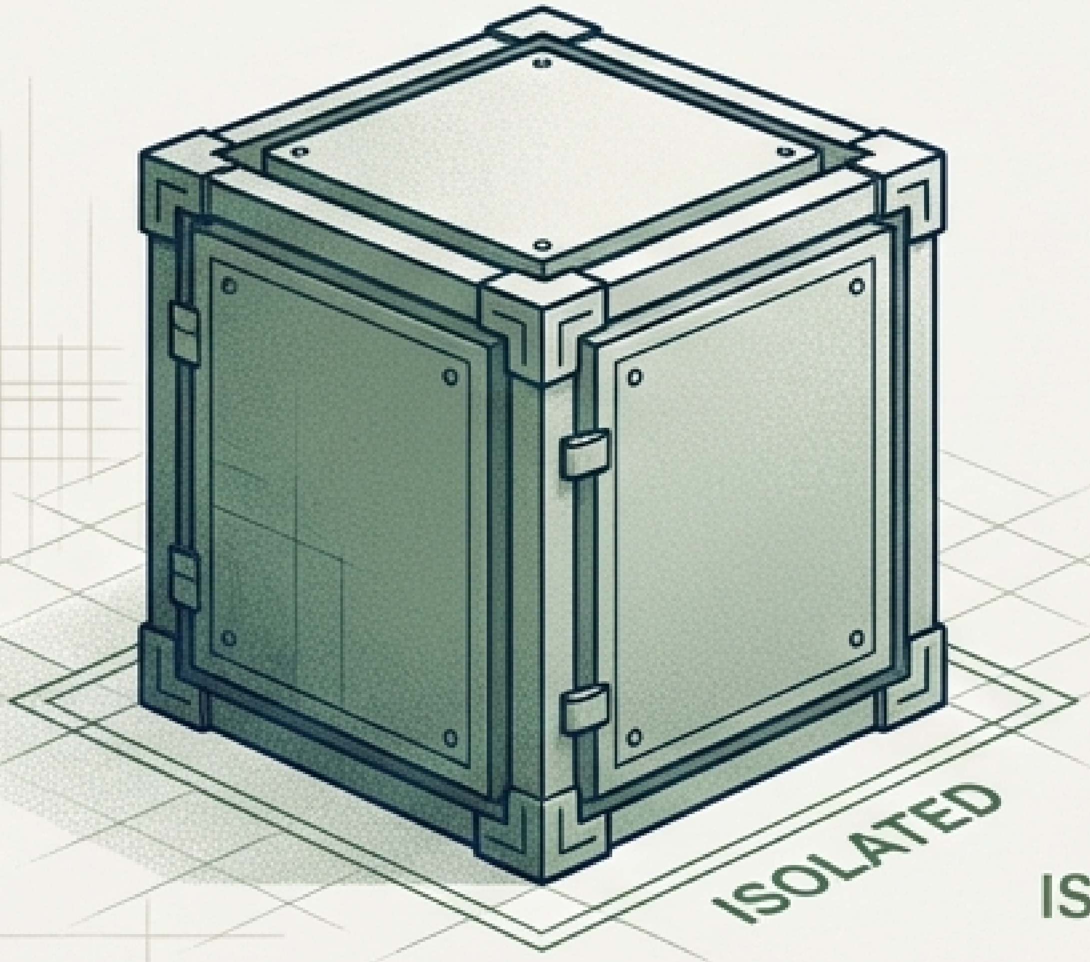
Auditable trust.
Moat is execution, hosted service, and support.

Criterion 7 Requires Complete Deployment Sovereignty and Isolation

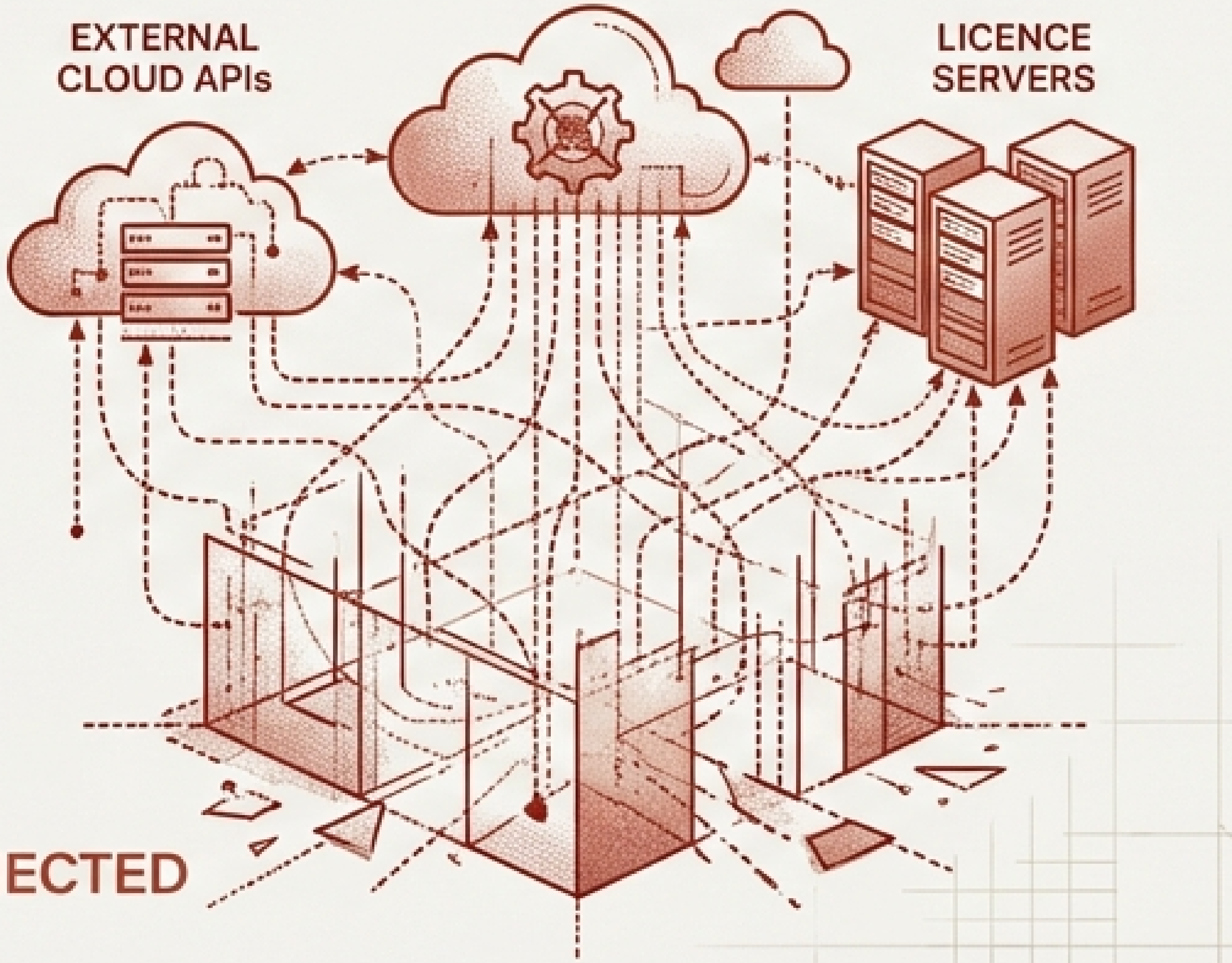
The question to ask: Can this product be deployed in a completely **air-gapped** environment with **zero communication** to external services or licence servers?

Why It Matters:

Removes vendor infrastructure as a single point of failure.
Unlocks classified, regulated, and privacy-sensitive environments.
Proves the architecture is self-contained without phone-home dependencies.



ISOLATED



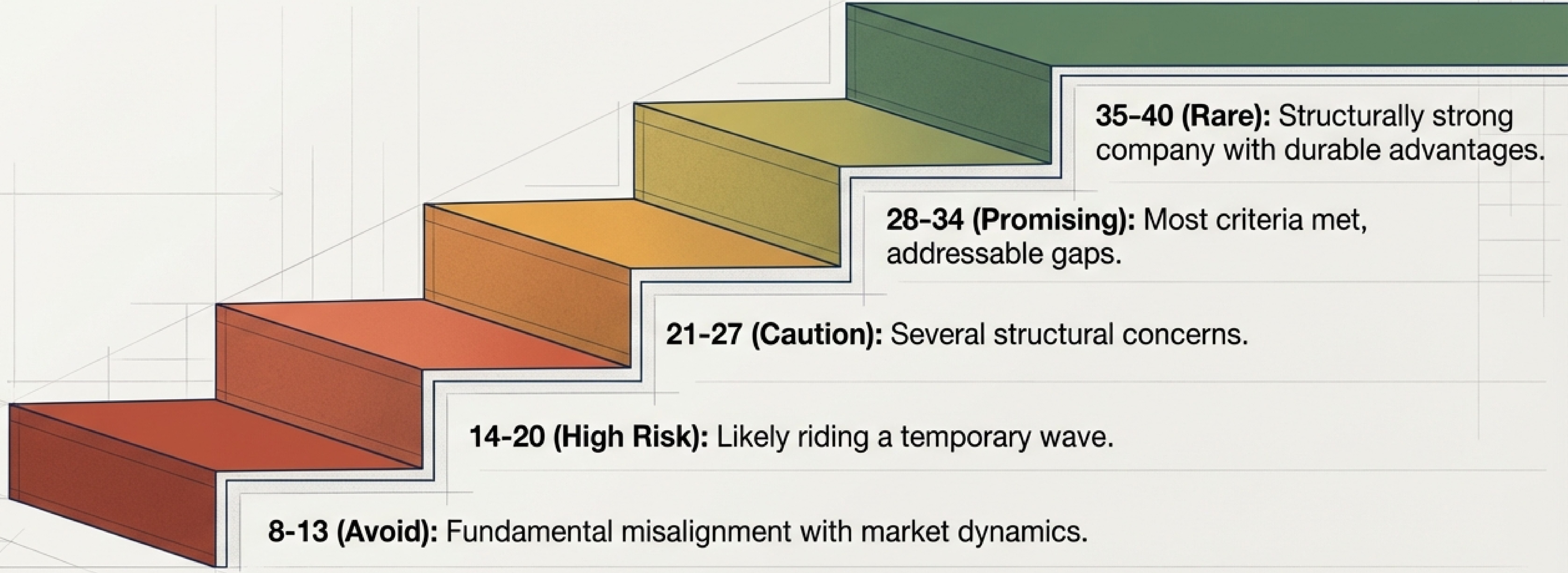
CONNECTED

The Complete GenAI Security Evaluation Scorecard

Criterion	Red Flag	Green Flag	Score (1-5)
1. Structural vs. Temporary	Solving symptoms	Solving fundamental problems	_/5
2. Unit Value	Requires enterprise rollout	Single team day-one value	_/5
3. Inline Risk	Inline single point of failure	Robust out-of-band handling	_/5
4. Business Context	LLM analysing LLM	Semantic graphs & permissions	_/5
5. Model Survivability	Value disappears	Value increases with new models	_/5
6. Open Source	Lock-in funnel	Genuine open core	_/5
7. Deployment Sovereignty	Centralised phone-home	Air-gappable self-service	_/5
Meta. Architecture	LLMs inline execution	Agentic dev/deterministic runtime	_/5

Calibrating Your Investment and Purchasing Decisions

Note: A score of 1 in any single category is a critical red flag that may be disqualifying.



Actionable Playbooks for Investors, Founders, and Buyers

Investors

Use during due diligence. Overweight Criteria 4 (business context) and 5 (model survivability) as the strongest predictors of long-term value.

Founders

Conduct honest self-assessment. Scoring poorly highlights urgent strategic pivots needed before market maturation.

Enterprise Buyers

Filter vendor pitches. Vendors with strong answers will still be relevant and supporting you in three years.

Practitioners

Calibrate your instincts using historical pattern recognition. If it feels like early SIEM failures, it probably is.

Defining the Boundaries of Structural Evaluation

What This Does NOT Evaluate:

- **Team Quality:** Crucial, but requires different assessment methods.
- **Current Traction:** Great traction frequently occurs in temporary markets.
- **Financial Metrics:** Revenue and burn rate are orthogonal to architectural durability.
- **Specific Technical Capabilities:** The framework remains deliberately technology-agnostic.
- **Go-to-Market Execution:** Structurally strong companies can still fail on execution.

Released under the Creative Commons Attribution 4.0 International licence (CC BY 4.0).